

מודול 9 — אבטחת OWASP Web (Top 10 — תרגול ותרחישים)

חומר לימוד

1 יחידות

תוכן העניינים

1. 🧠 תרגול — מודול 9: אבטחת Web (OWASP Top 10)

תרגול — מודול 9: אבטחת Web (OWASP Top 10) 🧠

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרחיש מהחיים האמיתיים.

חלק א' — שאלות תרגול

- Q1.** מהו השורש המשותף של רוב חולשות ה-Web?
- Q2.** מה עושה ה-payload `-- '1'='1' OR '1'='1'` בטופס התחברות, ומדוע?
- Q3.** מה ההבדל בין Reflected, Stored ו-DOM XSS? איזה החמור ביותר ולמה?
- Q4.** נתון `system("ping " . $_GET['ip'])`. איך תזריק פקודה נוספת, ולא יזו חולשה חמורה זה שקול?
- Q5.** מהי IDOR? תן דוגמה עם URL.
- Q6.** איך File Upload מוביל ל-RCE?
- Q7.** מה עושה sqlmap, ומה הדגל לשליפת בסיסי הנתונים?
- Q8.** אילו שתי הגנות מונעות XSS ו-SQLi בהתאמה?

תשובות ✅

- אמון בקלט משתמש** — קלט לא מסונן שמעובד כקוד/פקודה.
- `'1'='1'` תמיד אמת וה- `--` מבטל את בדיקת הסיסמה → עוקפים התחברות (מתחברים כמשתמש הראשון).
- Reflected=בבקשה, חוזר מיד; Stored=נשמר בשרת ופוגע בכל צופה; DOM=בצד הלקוח. **Stored** **החמור** — פוגע בכל המשתמשים ללא לינק.
- `127.0.0.1; whoami` (או `|`, `&&`); שקול ל-RCE (Remote Code Execution).
- Insecure Direct Object Reference — גישה למשאב של אחר ע"י שינוי מזהה. `site/account?id=1002`
- מעלים Web Shell (`<?php system($_GET['cmd']);>`) ומריצים פקודות דרכו → RCE.
- אוטומציית SQL Injection; `--dbs` לשליפת בסיסי הנתונים.
- SQLi → **Prepared Statements**; XSS → **Output Encoding** (+ CSP).

חלק ב' — תרחיש מהחיים האמיתיים

“בדיקת Bug Bounty ראשונה”

נרשמת לתוכנית Bug Bounty (בתוך Scope!) או שאתה מתרגל על **OWASP Juice Shop**. **בצע** בדיקה מובנית:

1. עבור על כל הדפים, מפה פרמטרים ונקודות קלט: Burp Proxy – מיפוי.
2. Injection – נסה בכל שדה קלט נסה:
' OR '1'='1' -- (SQLi)
<script>alert(1)</script> (XSS)
; whoami (Command Injection)
3. Access Control – שנה מזהים (id, user) → IDOR; ל- /admin נסה לגשת.
4. Upload/LFI – נסה shell.php; נסה ?file=../../etc/passwd.
5. sqlmap – על פרמטר חשוד: sqlmap -u "URL?id=1" --batch --dbs

המשימה: 1. מצא לפחות **3 חולשות** מקטגוריות שונות. 2. לכל אחת — כתוב ממצא: חומרה (CVSS), PoC (צעדים+צילום), ותיקון. 3. דרג לפי חומרה — מה תדווח ראשון ולמה.

פתרון מנחה

ב-Juice Shop תמצא בקלות: SQLi בהתחברות/חיפוש (Critical), Stored XSS בביקורות (High), IDOR בסל/הזמנות (Medium), גישת admin (High). **דווח ראשון על ה-Critical SQLi** — חושף את כל מסד הנתונים). מבנה הדוח = מודול 16.

 בדיקת Web היא הכי מבוקשת בשוק — כל ממצא שתתעד נכון הוא נכס לתיק העבודות ולראיונות.

 חזרה למודול · תרגילים מעשיים